

Requisitos para integração SSO — Limpidus Clean Check (Report)

Checklist para cliente / interno — o que solicitar antes de implementar SSO

Introdução

O Clean Check (Report) precisa validar se o usuário pode autenticar e qual o perfil de acesso (franqueado vs franqueador). Hoje não há SSO no sistema e não existe o papel “Franqueador”. Os papéis atuais são: Franqueado, Admin e ProjectViewer.

1. Identidade (IdP)

- ☐ Provedor de identidade (ex.: Azure AD / Entra ID, Okta, Google Workspace, ADFS, outro).
- ☐ Protocolo preferido: OIDC (recomendado) ou SAML 2.0.
- ☐ Tenant ID / Issuer / Authority (URL de descoberta OIDC, se aplicável).
- ☐ Client ID (e se haverá Client Secret / certificado — app confidencial vs pública).
- ☐ Redirect URIs de login e logout (homologação e produção).
- ☐ Claim estável para identificar o usuário (e-mail, oid, upn ou outro) — definir o campo canônico.
- ☐ Claims adicionais disponíveis (nome, grupos, roles customizadas).

2. Quem pode entrar

- ☐ Somente usuários já cadastrados em FRANQ_LOGIN? (sim/não)
- ☐ Regra de mapeamento: e-mail SSO != usuário interno (campo e regras de normalização).
- ☐ Comportamento se o usuário autenticar no IdP mas não existir no sistema (bloquear / criar / fluxo manual).
- ☐ Critério de usuário ativo (flag, data, status em FRANQ_LOGIN ou outra fonte).
- ☐ Domínios de e-mail permitidos (se houver restrição).

3. Franqueado vs Franqueador

- ☐ Definição de negócio: o que distingue Franqueado de Franqueador.
- ☐ Como o papel chega no SSO: claim customizado, grupo no IdP, ou consulta SQL / base Limpidus.
- ☐ Valor(es) esperados no claim/grupo para cada papel.
- ☐ O que cada perfil deve ver no Clean Check Report (escopo de telas, dados e ações).
- ☐ Um usuário pode ter ambos os papéis? Em quais condições?

4. Escopo de acesso

- ☐ Quais projetos cada papel enxerga (todos, por franquia, por vínculo explícito, etc.).
- ☐ Papel Admin: quem atribui, via SSO ou somente cadastro interno?
- ☐ ProjectViewer: permanece? Como se relaciona com SSO?
- ☐ Login de projeto (acesso por projeto sem usuário franqueado) passa a existir no SSO ou permanece fora?
- ☐ Regras de herança / múltiplos projetos por usuário.

5. Ambiente e operação

- ☐ URLs de homologação e produção do Clean Check Report.
 - ☐ Contatos técnicos do IdP (nome, e-mail, canal) e do negócio Limpidus.
 - ☐ Usuários de teste: pelo menos 1 Franqueado, 1 Franqueador (quando existir) e 1 Admin — credenciais/IDs no IdP.
 - ☐ Janela para cadastro do aplicativo no IdP e troca de metadados (certificados, secrets).
 - ☐ Política de rotação de secrets/certificados e responsável.
-

6. Mínimo para começar a implementar

- Provedor + protocolo (OIDC ou SAML) confirmados.
- Tenant / Client ID e redirect URIs de homologação.
- Claim estável de identidade (e-mail/oid/upn).
- Regra: só FRANQ_LOGIN vs provisionamento; e o que fazer se não achar o usuário.
- Como distinguir Franqueado vs Franqueador (claim, grupo ou SQL) — mesmo que provisório.
- 1–2 usuários de teste no IdP + contato técnico para ajustes.

Preencha os itens marcados com o cliente/IdP antes do desenvolvimento. Itens em aberto bloqueiam a definição de arquitetura e o cadastro da aplicação no provedor.
